

Rapport de sécurité - Mai 2026

Projet : Plateforme E2D

Date : 12 mai 2026

Statut global : [OK] Aucun finding actionnable - application durcie

1. Résumé exécutif

Indicateur	Valeur
Vulnérabilités critiques résolues	5
Vulnérabilités critiques restantes	0
Warnings du linter (acceptés)	103
Tests RLS automatisés	28
Dépendances npm critiques/hautes	0

Le re-scan du 12 mai 2026 (scanners `supabase_lov`, `supabase`, `agent_security`) ne remonte plus aucun finding actionnable. Les 103 warnings restants relèvent du linter brut Supabase et concernent des comportements **intentionnels** (vitrine publique, RPCs métier en `SECURITY DEFINER`).

2. Findings résolus

2.1 `messages_contact` - PII lisibles par tous les membres

- **Sévérité** : error
- **Risque** : tout membre connecté pouvait lire les soumissions du formulaire de contact (nom, email, téléphone, message).
- **Correctif** : politique `SELECT` restreinte à `is_admin()` OR `has_role('secretaire_general')`.
- **Vérifié** : [OK] test `messages_contact: anon/member cannot SELECT, admin CAN`.

2.2 `demandes_adhesion` - PII lisibles par tous les membres

- **Sévérité** : error
- **Risque** : demandes d'adhésion (identité + coordonnées) accessibles à tout membre.
- **Correctif** : `SELECT` réservé admin/secrétaire.
- **Vérifié** : [OK] test dédié.

2.3 Tables CMS - écriture publique

- **Sévérité** : error

- **Tables** : cms_events, cms_gallery, cms_hero_slides, cms_pages, cms_sections, cms_settings, cms_partners.
- **Risque** : tout membre pouvait modifier/supprimer le contenu vitrine.
- **Correctif** : SELECT public conservé (vitrine), INSERT/UPDATE/DELETE restreints à is_admin().
- **Vérifié** : [OK] tests member CANNOT INSERT × 7 tables.

2.4 fichiers_joint - métadonnées exposées en anonyme

- **Sévérité** : warn
- **Risque** : énumération anonyme des URLs de pièces jointes (justificatifs).
- **Correctif** : politique USING (true) sur le rôle public supprimée ; lecture authentifiée uniquement.
- **Vérifié** : [OK] test anon cannot SELECT.

2.5 Finances sport - recettes/dépenses publiques

- **Sévérité** : warn
- **Tables** : sport_e2d_depenses, sport_e2d_recettes, sport_phoenix_depenses, sport_phoenix_recettes.
- **Risque** : transactions financières internes lisibles par n'importe quel internet.
- **Correctif** : SELECT restreint aux utilisateurs authentifiés.
- **Vérifié** : [OK] tests anon cannot SELECT + member CAN SELECT × 4 tables.

3. Warnings acceptés (intentionnels)

Catégorie	Nombre	Justification
Public Bucket Allows Listing	10	Buckets vitrine (site-hero, site-gallery, site-partners, site-events, site-images, sport-logos, membre-photos, members-photos, match-medias) - listing publique attendu pour le site vitrine. Le bucket privé justificatifs n'est PAS listé.
Public Can Execute SECURITY DEFINER	~80	RPCs métier (get_caisse_synthese, has_role, is_admin, get_solde_caisse, etc.) - chaque fonction valide l'identité en interne via auth.uid(). Voir mem://security/configurations-rls-hardening.
RLS Policy Always True (SELECT)	~13	Tables CMS et autres données vitrine en lecture publique - comportement métier attendu.

Toutes ces acceptations sont consignées dans la mémoire sécurité du projet.

4. Tests automatisés (régression RLS)

Suite Vitest dédiée : `src/test/security/rls.test.ts`

- **28 cas** couvrant 18 tables sensibles
- 3 personae : anonyme / membre / admin
- Skip propre si les credentials de test ne sont pas configurés (pas de faux positif)
- Documentation : `docs/SECURITY_TESTS.md`
- Exécution : `npm run test:rls`

5. Recommendations

1. **Audit trimestriel** : relancer `security--run_security_scan` chaque trimestre.
2. **Rotation tokens** : `RESEND_API_KEY` et `LOVABLE_API_KEY` à renouveler tous les 6 mois.
3. **CI** : ajouter `npm run test:rls` au pipeline de déploiement (variables secrètes en `secrets.*`).
4. **Comptes de test** : créer 2 comptes dédiés `qa-membre@` et `qa-admin@` réservés à la suite RLS.
5. **Bucket justificatifs** : revue annuelle des règles d'accès aux pièces sensibles.

6. Annexes

6.1 Migrations sécurité 2026-05

- `20260505191935_*.sql` - durcissement initial (audit_logs, payment_configs, edge functions guards)
- `20260512154016_*.sql` - RLS de 14 tables sensibles + `current_membre_id()`
- `20260512180045_*.sql` - correctif des 5 findings ci-dessus

6.2 Documents liés

- `docs/CODE_REVIEW_2026_05.md`
- `docs/RLS_PERMISSIONS.md`
- `docs/SECURITY_DASHBOARD_ACTIONS.md`
- `docs/SECURITY_TESTS.md`